

JWTs

FastAPI Masterclass

JSON Web Token [JWT]

- A **JSON Web Token** (JWT) is a token/string that contains encoded user information.
- A server uses the JWT to identify the user.
- To “encode” means to convert information from one format to another.
- A JWT consists of **3** segments separated by dots.
 - **Header.Payload.Signature**

Base64URL Encoding I

- All 3 segments of a JWT are Base64URL-encoded strings.
- In this domain, encoding is the process of converting JSON into a string representation.
- The underlying data is not different. It's the same information but in a different translation.
- Base64URL-encoding uses 64 URL-safe characters: A-Z, a-z, 0-9, -, and _.

Base64URL Encoding II

- These Base64URL characters are less likely to have issues being parsed by browsers/servers.
- Other characters like spaces, `{}`, `“”`, `:` are more likely to break things.
- Base64 has fewer characters, so the string will be *longer*. It needs more characters to represent the original JSON.

Base64URL Encoding III

- Base64URL-encoding is *not* encrypting the data. It does not add any security.
- Anyone can transform the header + payload segments from the Base64URL string to the original JSON object.
- Base64URL-encoding exists to reduce the chance of errors in the *transport* of the token.

Header

```
{  
  "alg": "HS256",  
  "typ": "JWT"  
}
```



The **header** declares the algorithm used to sign the JWT.

```
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXV  
CJ9.eyJzdWUiOiJib3Jpc0BleGFtcGxlM  
NvbSIsIm5hbWUiOiJCb3JpcylsImFkb  
Wluljp0cnVILCJpYXQiOiE1MTYyMzkw  
MjJ9.kzsqedCrHxMACHxrmbtMNM23  
Bd2QFUav9WIOdPDIHlc
```

Payload

```
{  
  "sub": "boris@example.com",  
  "name": "Boris",  
  "admin": true,  
  "iat": 1516239022  
}
```



The **payload** stores the user information. Common properties include user ID, name, expiration time, etc.

```
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.  
eyJzdWliOiJib3Jpc0BleGFtcGxlLnN  
vbSlslm5hbWUiOiJCb3JpcylslmFkb  
Wluljp0cnVILCJpYXQiOiE1MTYyMzk  
wMjJ9.kzsqedCrHxMAChxrmbtMNM2  
3Bd2QFUav9WIOdPDHlc
```

Signature

e0a7af0b2fb790fe53a100f53bc72
93ab6ba7d88893a7cb885b4ec4c85
8c8a4a



The **signature** proves the token has not been tampered with. It is created using a secret key on the server.

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ
9.eyJzdWUiOiJib3Jpc0BleGFtcGxlLmNv
bSIsIm5hbWUiOiJCb3JpcylsImFkbWlu
ljp0cnVILCJpYXQiOiE1MTYyMzkwMjI
9.**kzsqedCrHxMAChxrmbtMNM23Bd**
2QFUav9WIOdPDIHlc